Veille technologique — Black October : l'IA et les failles PHP2Shell

Auteur : Joshua BERNARD · **Formation :** BTS SIO option SISR · **Date :** 27 octobre 2026 · **Version :** 1.0

1. Introduction

2. Mon sujet de veille

    2.1 Black October : l'IA et les failles PHP2Shell

    2.2 Objectifs de ma veille

3. Méthodologie et outils de veille

    3.1 La collecte : méthodes push et pull

    3.2 Feedly, agrégateur de flux RSS

    3.3 Google Alertes

    3.4 Qualité des sources

    3.5 Traitement et partage

4. Synthèse de la veille

    4.1 Chronologie de Black October

    4.2 Analyse technique

    4.3 Le rôle de l'IA

    4.4 Impacts pour un administrateur SISR

    4.5 Mesures de remédiation

    4.6 Cadre réglementaire

    4.7 Lien avec les dangers de l'IA

    4.8 Enjeux

5. Journal de suivi de la veille

6. Avis personnel

7. Conclusion et perspectives

Annexe A : Glossaire technique

Annexe B : Webographie

- Black October / PHP2Shell
- Cadre réglementaire
- Dangers de l'IA
- Alerte Google
- Feedly

1. Introduction

Durant ma formation, j'ai mis en place une veille technologique. La veille consiste à rechercher, collecter, traiter et partager des informations sur un domaine précis, afin d'aider à la prise de décision ou d'orienter ses choix technologiques.

En informatique, et particulièrement en cybersécurité, rester informé est indispensable : une faille découverte aujourd'hui peut être exploitée dans les heures qui suivent. L'objectif de cette veille est de permettre à une organisation d'adapter son infrastructure et ses pratiques face à ces nouvelles menaces.

Cette veille s'inscrit dans le bloc 1 du BTS SIO, compétence B1.6 « Organiser son développement professionnel », et plus précisément C1.6.2 : mettre en œuvre des outils et stratégies de veille informationnelle.

2. Mon sujet de veille

2.1 Black October : l'IA et les failles PHP2Shell

Le 21 octobre 2026, PHP a publié en urgence des correctifs pour deux failles critiques permettant de prendre le contrôle d'un serveur web à distance, sans mot de passe. Ces failles, trouvées avec l'aide de modèles d'IA, existaient depuis plus de dix ans. La presse a surnommé cet épisode « Black October ».

PHP est le langage serveur le plus répandu : il fait tourner environ 70 % des sites web, dont WordPress, Drupal, Joomla, Nextcloud ou phpMyAdmin. Ce sujet touche donc presque tous les parcs informatiques. Je l'ai choisi car il

réunit trois compétences du SISR : la sécurité des services, la gestion des mises à jour et la supervision. Il montre aussi un tournant : l'IA change la vitesse à laquelle on trouve et exploite les failles.

2.2 Objectifs de ma veille

- Comprendre comment l'IA change la découverte et l'exploitation des failles de sécurité.
- Suivre l'évolution de PHP2Shell : correctifs, exploitation réelle, nouvelles alertes.
- Identifier les bonnes pratiques qu'un administrateur systèmes et réseaux doit appliquer.
- Suivre le cadre réglementaire (NIS2, AI Act) qui encadre ces risques.

3. Méthodologie et outils de veille

Ma veille suit les quatre étapes vues en cours :

1. **Objectifs** : définir ce que je veux savoir.
2. **Collecte** : push (alertes, flux RSS) et pull (recherches).
3. **Traitement** : trier, recouper, synthétiser.
4. **Partage** : portfolio et document de veille.

3.1 La collecte : méthodes push et pull

J'utilise les deux méthodes de collecte. La méthode **push** fait remonter l'information automatiquement (flux RSS, alertes par courriel) : je ne rate rien d'important, mais il faut trier un grand volume. La méthode **pull** consiste à chercher moi-même, régulièrement, de nouvelles informations : elle permet d'aller plus loin sur un point précis, comme une CVE ou un avis du CERT-FR.

3.2 Feedly, agrégateur de flux RSS

Feedly est un agrégateur de flux RSS : il regroupe dans une seule page les nouveaux articles de plusieurs sites, avec des fonctions de tri et de filtrage. J'y ai créé une collection « Cybersécurité » qui regroupe les sources suivantes :

- **CERT-FR (ANSSI)** : alertes et avis de sécurité officiels en France.
- **BleepingComputer** et **The Hacker News** : actualité des failles et des attaques.

- **SecurityWeek** : suivi détaillé de l'exploitation des failles.
- **Le Monde Informatique** : actualité IT en français.

3.3 Google Alertes

Google Alertes m'envoie un courriel dès qu'une nouvelle page correspond à mes mots-clés. Contrairement à Feedly, il ne dépend pas de flux RSS : il explore tout le web. J'ai configuré des alertes sur « PHP2Shell », « Black October », « faille PHP » et « IA cybersécurité ».

3.4 Qualité des sources

Type de source	Exemples	Usage
Organismes officiels	CERT-FR (ANSSI), CERT-EU, CISA, php.net	Alertes et avis de sécurité de référence
Presse spécialisée IT	Le Monde Informatique, BleepingComputer, SecurityWeek	Suivi de l'actualité
Presse internationale	CNBC, CNN, IT Jungle	Portée mondiale et réactions des experts
Chercheurs et éditeurs	Wiz, Sansec, Tenable, Cloudflare	Détails techniques de première main

Pour chaque information, je vérifie sa crédibilité (qui l'écrit ?), sa fiabilité et son exactitude (est-elle confirmée par une deuxième source ?), son objectivité (est-ce un avis commercial ?), son actualité (de quand date-t-elle ?) et sa pertinence pour mon sujet.

3.5 Traitement et partage

Je trie les articles reçus, je garde ceux qui apportent une information nouvelle et je les recoupe avec une deuxième source. Je classe ensuite les liens utiles par thème dans Pearltrees (Chronologie, Technique, IA, Réglementation). Ce document, publié dans mon portfolio, constitue le partage de ma veille. Le journal de suivi (partie 5) montre son évolution dans le temps.

4. Synthèse de la veille

4.1 Chronologie de Black October

Date (2026)	Événement
1er août	Calif, aidée par GPT-5.6 Sol (OpenAI), identifie des chemins d'exécution de code
11 août	Calif signale le premier bug à PHP
19 août	Wiz Research trouve les failles avec Gemini 4 Argon et GPT-5.6 Sol
24 août	Wiz transmet ses rapports à l'équipe sécurité de PHP
17 octobre	Amazon observe une première tentative d'utilisation du code d'exploitation
20 octobre	Fuite des détails et d'une vidéo d'outil d'exploitation ; PHP avance la sortie du correctif
21 octobre, 3h02 UTC	Cloudflare active des règles WAF pour ses clients avant la divulgation
21 octobre, vers 13h30 UTC	Publication des correctifs PHP ; alerte CERTFR-2026-ALE-014 du CERT-FR ; des sites sont mis hors ligne par précaution

La divulgation coordonnée était prévue le 22 octobre. La fuite a raccourci le délai et obligé la communauté PHP à accélérer.

4.2 Analyse technique

Les termes techniques (worker, memory_limit, CVE, CVSS, RCE…) sont définis dans le glossaire en annexe A. Pour comprendre la faille, on peut imaginer un employé de bureau (le worker) qui traite des dossiers (les requêtes). Chaque dossier a droit à une place limitée sur le bureau (memory_limit).

1. Le pirate envoie un dossier volontairement énorme, par exemple un faux envoi de fichier.
2. La place autorisée est dépassée : PHP arrête tout d'un coup, sans ranger le bureau.
3. Des papiers restent sur le bureau, à moitié remplis ou périmés.
4. Le dossier suivant est traité par le même employé, qui fait confiance à ces papiers sans les vérifier.
5. Si le pirate a glissé ses propres instructions dans ces papiers, l'employé les exécute : le pirate contrôle le serveur.

- **CVE-2026-109618** : quand PHP s'arrête brutalement, des données restent à moitié remplies, notamment pendant l'envoi d'un fichier. PHP les réutilise

ensuite comme si elles étaient correctes.

- **CVE-2026-109619** : une zone de mémoire déjà rendue reste notée comme utilisable. La requête suivante peut tomber dessus. Ce chemin passe par la fonction qui suit la progression des envois de fichiers (`session.upload_progress`).

Les deux failles sont notées 9,2 sur 10 et permettent une RCE. Elles sont graves pour trois raisons : aucun mot de passe n'est nécessaire, l'attaque a lieu dans PHP lui-même (même un WordPress à jour est vulnérable si PHP ne l'est pas), et presque toutes les versions sorties depuis 2012 sont touchées (5.4 à 8.5), quel que soit le mode d'installation.

4.3 Le rôle de l'IA

- **Côté défense** : les chercheurs de Wiz et de Calif ont utilisé des modèles d'OpenAI et de Google pour trouver les failles, écrire une preuve d'exploitation et valider le correctif. Selon Wiz, un seul chercheur a fait en une semaine le travail qui aurait demandé des mois à une équipe d'experts. OpenAI parle de « Defender's Window » : l'IA a laissé deux mois aux défenseurs pour préparer les correctifs.
- **Côté attaque** : dès la publication, des tentatives d'exploitation ont utilisé des codes générés avec l'IA. Comparer l'ancien et le nouveau code pour retrouver la faille ne prend plus que quelques heures.
- **À nuancer** : Calif estime que la connaissance de l'historique de PHP a autant compté que le modèle. L'IA accélère un expert, elle ne le remplace pas.

4.4 Impacts pour un administrateur SISR

- **Le délai entre divulgation et attaque se compte en heures.** Un cycle de mise à jour mensuel ne suffit plus pour les services exposés à Internet.
- **L'inventaire est vital.** Il faut savoir en quelques minutes où tourne PHP et en quelle version (outil type GLPI, OCS Inventory).
- **Les versions obsolètes deviennent un risque immédiat.** Environ 36 % des sites WordPress tournent sur une version de PHP antérieure à 8.2, qui n'est plus corrigée. PHP 8.2 sort lui-même du support le 31 décembre 2026.
- **Le WAF aide mais ne suffit pas.** Cloudflare présente ses règles comme une protection temporaire en attendant le correctif.

- **Disponibilité contre sécurité.** Des gouvernements et des entreprises comme Nintendo ont coupé des sites par précaution : c'est un arbitrage que l'administrateur doit savoir justifier.

4.5 Mesures de remédiation

1. Mettre à jour vers PHP 8.5.12, 8.4.27, 8.3.36 ou 8.2.35 (ou le paquet corrigé de la distribution, ex. `apt upgrade` sous Debian).
2. Redémarrer PHP-FPM ou Apache : tant que les anciens processus tournent, le serveur reste vulnérable.
3. Pour PHP 8.1 et plus ancien : isoler les serveurs exposés, appliquer les correctifs exceptionnels (7.4, 8.0, 8.1) et planifier la migration.
4. Si la mise à jour est impossible tout de suite : désactiver `session.upload_progress.enabled` dans php.ini, limiter `post_max_size`, surveiller ou filtrer les requêtes multipart.
5. Superviser les journaux : erreurs mémoire, rafales d'erreurs 500, cookies `PHPSESSID` anormalement longs. En cas de doute, considérer le serveur comme compromis.

4.6 Cadre réglementaire

NIS2 oblige les organisations jugées essentielles ou importantes (plus de 15 000 en France) à gérer leurs failles, appliquer les correctifs et déclarer leurs incidents. Avec NIS2, réagir vite à une crise comme Black October deviendrait une obligation légale. Pourtant, la France ne l'a toujours pas transposée : le projet de loi « Résilience », adopté par le Sénat le 12 mars 2025, a encore été retiré de l'ordre du jour de l'Assemblée le 6 octobre 2026, et la Commission européenne a saisi la Cour de justice de l'UE le 8 juillet 2026. En attendant, l'ANSSI a publié un référentiel de travail, le ReCyF.

L'AI Act, règlement européen sur l'IA, s'applique de façon générale depuis le 2 août 2026, avec des sanctions pouvant aller jusqu'à 35 millions d'euros ou 7 % du chiffre d'affaires mondial. Les obligations de transparence sont en vigueur, mais les règles sur les IA « à haut risque » ont été reportées au 2 décembre 2027.

Ces deux textes montrent un décalage : la loi avance par étapes et avec des reports, alors que l'IA a permis de trouver puis d'exploiter PHP2Shell en quelques semaines.

4.7 Lien avec les dangers de l'IA

Black October n'est pas un accident isolé. Le Rapport international sur la sécurité de l'IA 2026, dirigé par Yoshua Bengio avec plus de 100 experts, constate des progrès rapides en programmation et en tâches autonomes. Il reste prudent : d'ici 2030, l'IA pourrait ralentir, plafonner ou accélérer fortement. L'idée d'une accélération « inarrêtable » est donc un débat, pas une certitude.

Date	Fait
Septembre 2025	Anthropic détecte la première cyberattaque documentée pilotée par une IA : 80 à 90 % des opérations faites par l'IA
Avril 2026	Claude Mythos Preview (Anthropic) trouve des milliers de failles zero-day ; son accès est réservé à des défenseurs (Project Glasswing)
Juin 2026	Des contrôles à l'exportation américains conduisent Anthropic à suspendre l'accès à deux modèles du 12 juin au 1er juillet : l'IA est traitée comme une technologie stratégique
Septembre 2026	Google réserve Gemini 4 Argon au gouvernement américain et à des défenseurs cyber
Octobre 2026	Black October : failles trouvées avec l'IA, exploitées en quelques heures

Les risques annoncés pour les dix prochaines années sont une IA plus forte que les humains en cyberattaque d'ici 2030 (selon le chercheur Jacob Steinhardt), des rançongiciels menés presque entièrement par des IA autonomes (prévision de l'éditeur Check Point, à prendre avec recul), des attaques à la portée de personnes sans expertise, et une surveillance humaine plus difficile à mesure que les systèmes deviennent autonomes.

4.8 Enjeux

Cet épisode montre que la complexité d'un bug ne protège plus : l'IA trouve des failles enfouies depuis des années, et les experts annoncent un « tsunami de vulnérabilités ». La leçon principale pour un administrateur est organisationnelle : garder ses versions dans le support, connaître son parc et avoir une procédure de correctif d'urgence répétée à l'avance. L'IA doit aussi entrer dans les outils de défense, pas seulement chez les attaquants.

5. Journal de suivi de la veille

Ce journal est alimenté par mes alertes et mon fil Feedly, et mis à jour jusqu'à l'examen.

Date	Fait	Source
21/10/2026	PHP publie les correctifs ; le CERT-FR publie son alerte ; des sites sont coupés par précaution	SFEIR
23/10/2026	La presse américaine popularise le nom « Black October » ; la CISA publie une règle de détection mais n'a pas encore vu d'attaque réussie	CNBC, SecurityWeek
24/10/2026	Premières attaques réussies confirmées sur des serveurs pièges (honeypots) : 35 prises de contrôle depuis deux adresses IP	SecurityWeek
26/10/2026	La CISA ajoute les deux CVE à son catalogue des failles activement exploitées (KEV) ; les agences fédérales américaines doivent corriger avant le 29/10	BleepingComputer
27/10/2026	Des chercheurs signalent des scans suspectés d'être liés à la Corée du Nord (non confirmé)	SecurityOnline

6. Avis personnel

Black October m’a surtout inquiété. Je savais que l’IA progressait vite, mais voir une telle facilité pour trouver des failles de plus de 10 ans, ça fait peur. L’IA va rendre Internet plus dangereux, parce que les pirates n’ont besoin que d’une faille pour détruire le travail d’une entreprise alors que les défenseurs doivent tout protéger et tout corriger tout le temps. Cette veille m’a montré qu’elles ne suffisent plus si on ne suit pas l’actualité. C’est pour ça que j’ai mis en place des alertes et que je compte rester actif sur ces sujets. En tant que futur technicien, il est surtout nécessaire de bien comprendre comment utilisé l’IA en tant qu’outil et non pas en tant que remplaçant.

7. Conclusion et perspectives

Black October montre que l'IA bouleverse déjà la sécurité informatique : les failles sont trouvées et exploitées beaucoup plus vite, ce qui oblige les administrateurs à mieux connaître leur parc et à corriger en quelques heures. Pour un futur technicien SISR, la veille est indispensable pour réagir vite aujourd'hui et anticiper les menaces de demain.

- OpenAI annonce d'autres failles importantes en cours de correction.

- La divulgation coordonnée doit s'adapter à des découvertes plus nombreuses et plus rapides.
- À suivre : les nouvelles alertes du CERT-FR, l'évolution de l'exploitation de PHP2Shell et la transposition de NIS2 en France.

Annexe A : Glossaire technique

Terme	Définition
AI Act	Règlement européen qui encadre les usages de l'intelligence artificielle.
Agrégateur RSS	Outil (Feedly, Netvibes…) qui regroupe les nouveaux articles de plusieurs sites au même endroit.
CERT-FR	Centre gouvernemental français (rattaché à l'ANSSI) qui publie les alertes de sécurité.
Correctif (patch)	Mise à jour qui répare une faille.
CVE	Numéro officiel d'une faille, comme une plaque d'immatriculation.
CVSS	Note de gravité d'une faille, de 0 à 10. Au-dessus de 9, elle est critique.
Divulgation coordonnée	Les chercheurs préviennent l'éditeur en secret et attendent que le correctif soit prêt avant de rendre la faille publique.
Faille (vulnérabilité)	Défaut dans un logiciel qu'un pirate peut utiliser.
Honeypot	Serveur piège installé volontairement pour observer les attaques.
KEV	Catalogue de la CISA (agence américaine) qui liste les failles réellement exploitées par des attaquants.
memory_limit	Quantité maximale de mémoire qu'une requête PHP a le droit d'utiliser.
Mémoire vive (RAM)	Espace de travail temporaire du serveur.
NIS2	Directive européenne qui impose des règles de cybersécurité aux organisations essentielles et importantes.
PHP	Langage qui fabrique les pages d'un site web sur le serveur, au moment où on les demande.
RCE (Remote Code Execution)	Le pirate peut faire exécuter ses propres commandes sur le serveur, à distance : il en prend le contrôle.

Terme	Définition
Requête	Demande envoyée par le navigateur au serveur (afficher une page, envoyer un fichier…).
Serveur web	Ordinateur allumé en permanence qui héberge un site et répond aux visiteurs.
WAF	Pare-feu applicatif web : filtre placé devant le site qui bloque les requêtes suspectes.
Worker	Processus du serveur qui traite les requêtes PHP les unes après les autres.
Zero-day	Faille inconnue de l'éditeur : aucun correctif n'existe encore.

Annexe B : Webographie

Sources consultées entre le 21 et le 27 octobre 2026.

Black October / PHP2Shell

- SFEIR – PHP2Shell : l'IA a trouvé la faille avant les attaquants (21/10/2026, mis à jour le 26/10)
- CNBC – AI's 'Black October': Critical PHP flaws set off global security scramble (23/10/2026)
- IT Jungle – Critical PHP2Shell Security Vulns Evoke 'Black October' (26/10/2026)
- ABC7 / CNN – Some websites shut down globally after AI finds critical PHP flaw (22/10/2026)
- KuCoin News – Le piratage piloté par l'IA révèle des failles critiques dans PHP (24/10/2026)
- CERT-FR – Alerte CERTFR-2026-ALE-014 (21/10/2026)
- PHP – Annonces de sécurité 2026 (20 et 21/10/2026)
- SecurityWeek – PHP2Shell : exploitation réussie (26/10/2026)
- BleepingComputer – CISA confirme l'exploitation de PHP2Shell (27/10/2026)
- SecurityOnline – PHP2Shell ajouté au catalogue KEV (27/10/2026)

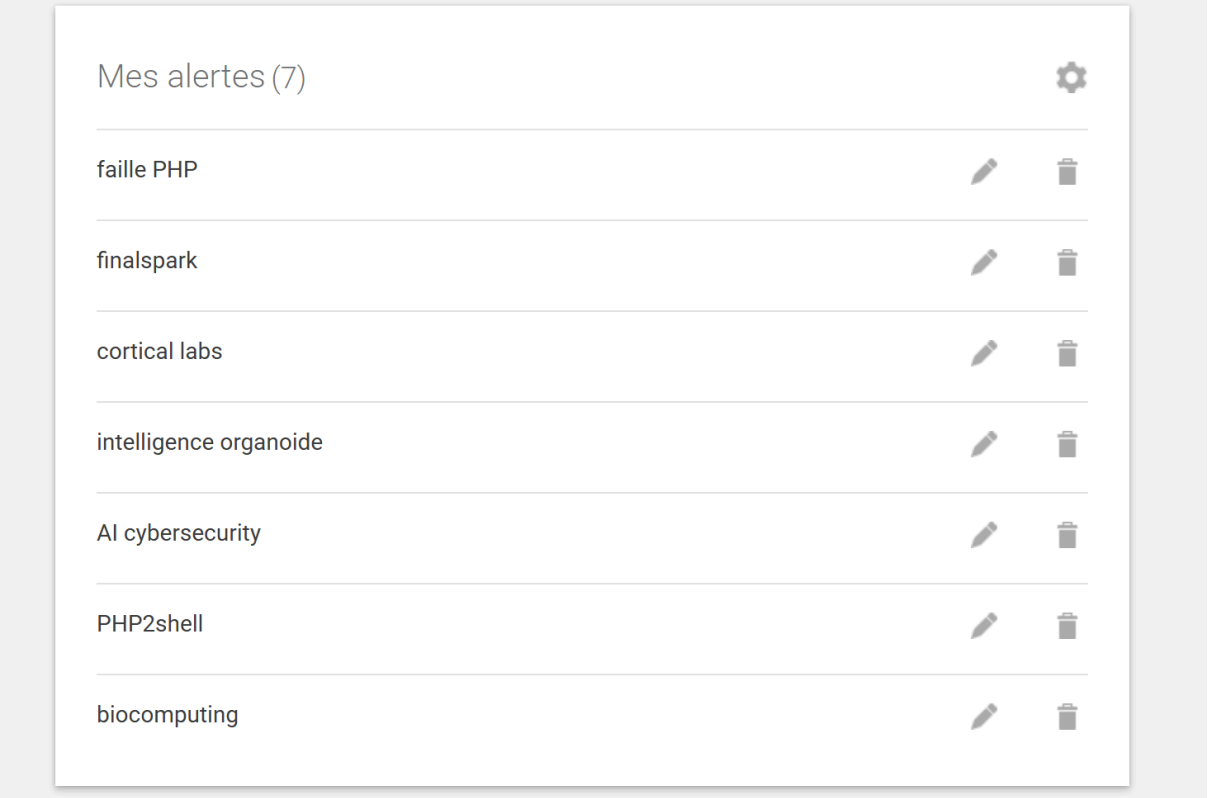
Cadre réglementaire

- Myra Security – NIS2 en France : où en est la loi Résilience (mis à jour le 12/10/2026)
- NIS Solutions – France still has no NIS2 law (10/08/2026)
- Données personnelles – Omnibus IA : le nouveau calendrier de l'AI Act (septembre 2026)
- Quantic Avocats – IA Act : le calendrier des obligations haut risque reporté (22/07/2026)

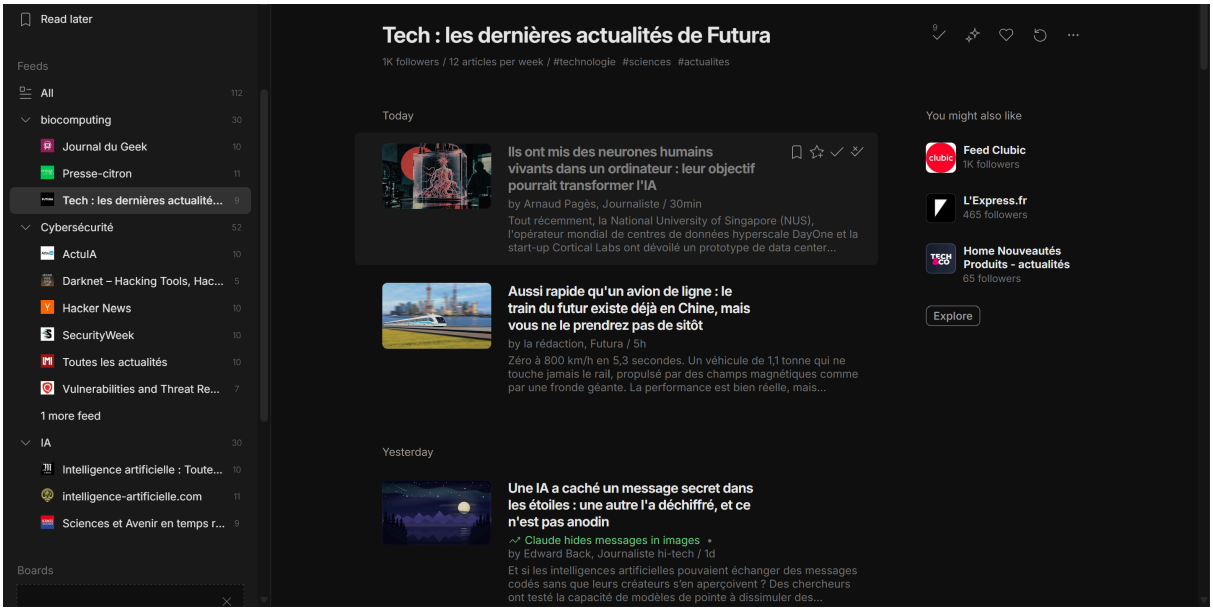
Dangers de l'IA

- CADE – Second International AI Safety Report 2026 (février 2026)
- Institut des sciences stratégiques – L'IA et les cyberconflits (2026)
- Tech Insider – Claude Mythos Preview et Project Glasswing (avril 2026)
- Anthropic – Accès à Fable et Mythos (juillet 2026)
- La Presse – L'IA surpassera les humains en cyberattaque d'ici 2030 (30/10/2024)
- Check Point – AI 2030: The Coming Era of Autonomous Cyber Crime (2025)

Alerte Google


Mes alertes (7)
faille PHP
finalspark
cortical labs
intelligence organoide
AI cybersecurity
PHP2shell
biocomputing

Feedly


Read later
Feeds
All
biocomputing
Journal du Geek
Presse-citron
Tech : les dernières actualité...
Cybersécurité
ActuIA
Darknet – Hacking Tools, Hac...
Hacker News
SecurityWeek
Toutes les actualités
Vulnerabilities and Threat Re...
1 more feed
IA
Intelligence artificielle : Toute...
intelligence-artificielle.com
Sciences et Avenir en temps r...
Boards
Tech : les dernières actualités de Futura
1K followers / 12 articles per week / #technologie #sciences #actualites
Today
Ils ont mis des neurones humains vivants dans un ordinateur : leur objectif pourrait transformer l'IA
by Arnaud Pagès, Journaliste / 30min
Tout récemment, la National University of Singapore (NUS), l'opérateur mondial de centres de données hyperscale DayOne et la start-up Cortical Labs ont dévoilé un prototype de data center...
Aussi rapide qu'un avion de ligne : le train du futur existe déjà en Chine, mais vous ne le prendrez pas de sitôt
by la rédaction, Futura / 5h
Zéro à 800 km/h en 5,3 secondes. Un véhicule de 1,1 tonne qui ne touche jamais le rail, propulsé par des champs magnétiques comme par une fronde géante. La performance est bien réelle, mais...
Yesterday
Une IA a caché un message secret dans les étoiles : une autre l'a déchiffré, et ce n'est pas anodin
Claude hides messages in images
by Edward Back, Journaliste hi-tech / 1d
Et si les intelligences artificielles pouvaient échanger des messages codés sans que leurs créateurs s'en aperçoivent ? Des chercheurs ont testé la capacité de modèles de pointe à dissimuler des...
You might also like
Feed Clubic
1K followers
L'Express.fr
465 followers
Home Nouveautés Produits - actualités
65 followers
Explore